Security Scan Report

Automated Web Security Scanner v1.0 • Scanned at (UTC): 2026-10-20T19:44:03.987310+00:00

Target	`http://127.0.0.1:8080/vulnerable`
Final URL	`http://127.0.0.1:8080/vulnerable`
HTTP Status	`200`
Response Time	45.33 ms

7	1	2
TOTAL FINDINGS	HIGH	MEDIUM

3	1
LOW	INFO / PRESENT

Inspection Findings & Recommendations

MEDIUM **Content Security Policy (CSP)** MISSING

Check: `content-security-policy`

Observed Evidence:

```
No content-security-policy header was observed in the final response.
```

> **Remediation Guidance:**
> Define a CSP suited to the application; begin with report-only mode if needed.

INFO **HTTP Strict Transport Security (HSTS)** NOT_APPLICABLE

Check: `strict-transport-security`

Observed Evidence:

```
Final response URL is not HTTPS.
```

> **Remediation Guidance:**
> HSTS is delivered over HTTPS; configure HTTPS first, then review HSTS.

LOW **X-Content-Type-Options** MISSING

Check: `x-content-type-options`

Observed Evidence:

```
No x-content-type-options header was observed in the final response.
```

> **Remediation Guidance:**
> Set X-Content-Type-Options: nosniff.

LOW **Referrer-Policy** MISSING

Check: `referrer-policy`

Observed Evidence:

```
No referrer-policy header was observed in the final response.
```

> **Remediation Guidance:**
> Set a deliberate Referrer-Policy, such as strict-origin-when-cross-origin, based on application needs.

LOW **Permissions-Policy** MISSING

Check: `permissions-policy`

Observed Evidence:

```
No permissions-policy header was observed in the final response.
```

> **Remediation Guidance:**

Consider restricting browser features that the application does not need.

MEDIUM **Framing protection** REVIEW

Check: `clickjacking_protection`

Observed Evidence:

```
Neither X-Frame-Options nor a CSP frame-ancestors directive was observed.
```

Remediation Guidance:

If the site should not be embedded by arbitrary origins, configure CSP frame-ancestors or X-Frame-Options.

HIGH **CORS configuration** REVIEW

Check: `cors`

Observed Evidence:

```
OPTIONS response included Access-Control-Allow-Origin: * and Access-Control-Allow-Cred
```

Remediation Guidance:

Review the server's CORS implementation. Browsers reject wildcard origins with credentialed requests, but this combination still warrants configuration review.

Scope & Limitations:

- Only one GET request and one OPTIONS request are sent; this is not a crawler.
- The scanner does not test authentication, authorization, application logic, injection, or exploitability.
- Header presence is not proof that a policy is correctly configured.
- CORS behavior may vary by endpoint and request; manual review is required.
- Run only against systems you own or have explicit permission to assess.